

Lumma Stealer / LummaC2 Malware Analysis Report

Report ID: LBC-MA-2026-001

Prepared for: RAIccoon Reports

Report type: Malware Analysis / Threat Intelligence

Date: 2026-06-01

TLP: CLEAR

Primary malware family: Lumma Stealer, also known as LummaC2

MITRE ATT&CK software ID: S1213

Risk rating: High

Executive Summary

Lumma Stealer, commonly tracked as LummaC2, is a Windows-focused information stealer sold as malware-as-a-service. It has been active since at least 2022 and is used by financially motivated actors to steal browser credentials, session cookies, cryptocurrency wallet material, application data, documents, host metadata, and other sensitive information. Microsoft tracks the developer and maintainer of the Lumma malware, C2 infrastructure, and MaaS ecosystem as Storm-2477.

Lumma should be treated as a high-severity intrusion even when it appears to be limited to a single workstation. The primary business impact is not only local data theft; stolen cookies, credentials, MFA-related artifacts, VPN profiles, email client data, FTP credentials, and crypto wallet data can enable follow-on account takeover, cloud compromise, business email compromise, fraudulent financial activity, and ransomware intrusion. Microsoft has observed ransomware actors including Octo Tempest, Storm-1607, Storm-1113, and Storm-1674 using Lumma in campaigns.

In May 2025, Microsoft, Europol, law enforcement, and industry partners announced a coordinated disruption of Lumma infrastructure. Microsoft reported identifying more than 394,000 globally infected Windows computers between March 16 and May 16, 2025, and the disruption targeted approximately 2,300 malicious domains associated with Lumma operations. This reduced infrastructure capacity, but it should not be interpreted as eradication. Lumma's MaaS model, affiliate distribution ecosystem, and use of rapidly shifting infrastructure make recurrence and retooling likely.

Key Judgments

- Lumma is a credential theft and session theft threat first, but it also supports follow-on payload delivery and plugin deployment.
- Current campaigns rely heavily on social engineering and trusted-platform abuse, including phishing, malvertising, fake software downloads, compromised websites, GitHub abuse, fake CAPTCHA / ClickFix lures, and loader malware.
- Lumma operators and affiliates use flexible infrastructure, including hardcoded C2 domains, fallback C2 references through Telegram and Steam profiles, Cloudflare-proxied infrastructure, encrypted HTTPS traffic, and changing C2 protocol details across versions.
- Endpoint response should include credential reset and token revocation, not merely malware removal.

- A Lumma infection should trigger investigation of browser credential stores, cloud identity logs, OAuth grants, VPN usage, mailbox rules, crypto wallet exposure, and lateral movement attempts.

Malware Overview

Lumma Stealer is an infostealer MaaS offering. Affiliates purchase access, use a panel to build malware binaries, manage C2 communications, and retrieve stolen data. Microsoft describes the core malware as written in a combination of C++ and assembly, protected by obfuscation mechanisms such as LLVM-based virtualization, control-flow flattening, control-flow obfuscation, stack decryption, large stack variables, and dead code. Microsoft also reports use of low-level syscalls and Heaven's Gate techniques in critical API implementation.

The malware family is designed for theft from browsers and user applications, especially Chromium- and Mozilla-based browsers. Its target profile includes saved passwords, cookies, autofill data, wallet files, cryptocurrency browser extensions, VPN profiles, FTP clients, email clients, Telegram data, user documents, and host metadata. Lumma can also retrieve additional configuration from C2 and has been observed installing plugins or additional malware, including clipboard stealers and coin miners.

Victimology and Targeting

Lumma is opportunistic and affiliate-driven. It targets individuals, enterprises, and critical infrastructure organizations rather than a single vertical. Campaign lures frequently exploit user trust in well-known brands, popular utilities, browser updates, invoices, cracked software, CAPTCHA prompts, and developer or gaming communities.

Commonly exposed groups include:

- Users who store passwords or payment data in browsers.
- Developers downloading tools, scripts, packages, or extensions from public repositories and marketplaces.
- Finance, help desk, and operations staff exposed to invoice, reservation, or account notification lures.
- Cryptocurrency users with local wallets or browser wallet extensions.
- Organizations without strong endpoint controls, application control, web filtering, and phishing-resistant MFA.

Delivery and Initial Access

Observed delivery methods include:

Vector	Description	Defensive concern
Phishing emails	Brand, invoice, hotel reservation, cancellation, subscription, or education-themed lures with malicious	Email security, URL rewriting, user reporting, attachment detonation, and post-delivery removal are important.

Vector	Description	Defensive concern
	links or attachments.	
Malvertising	Poisoned search ads for software-related searches such as browser updates or utility downloads.	Users may believe they are downloading legitimate software from vendor-like pages.
Compromised websites	Injected JavaScript on legitimate sites redirects users to payloads, lures, or intermediary scripts.	Reputation-based blocking alone may miss compromised trusted sites.
Fake CAPTCHA / ClickFix	Users are instructed to copy and run commands through Windows Run under the pretense of verification.	Creates suspicious RunMRU artifacts and living-off-the-land command execution.
Trojanized applications	Cracked, pirated, or spoofed installers silently execute Lumma.	Application control and blocking unsigned/untrusted binaries are important.
Trusted platform abuse	Public repositories and services such as GitHub are abused to host scripts or binaries.	Download source reputation and developer workflow controls matter.
Loader malware	Other malware, including loaders such as DanaBot, may deploy Lumma as an additional payload.	Detection should consider multi-payload intrusions.

Execution Chain

The exact chain varies by affiliate and campaign. Common execution patterns include:

1. User receives a lure or lands on a compromised or spoofed page.
2. The lure causes download and execution of a payload, or instructs the user to run a command.
3. ClickFix-style chains often place commands in the clipboard and instruct the user to paste into Windows Run.
4. The command may invoke `mshta`, `powershell`, `curl`, `iwr`, `irm`, JavaScript, or Base64-encoded content.
5. Intermediate scripts retrieve and execute Lumma, sometimes in memory.
6. Lumma initializes, resolves C2, retrieves configuration, collects targeted data, and exfiltrates stolen content.
7. Depending on configuration, Lumma may retrieve plugin instructions or deploy additional malware.

CISA describes observed LummaC2 execution beginning with `LummaC2.exe` entering a main

routine with multiple subroutines. The advisory notes string decryption, user prompt behavior in analyzed samples, callback domain decryption, and HTTP POST requests to decoded C2 domains.

Technical Capabilities

Credential and Browser Theft

Lumma targets Chromium, Edge, Mozilla, and Gecko-based browsers. Data theft commonly includes:

- Saved passwords.
- Session cookies.
- Autofill data.
- Browser extension data.
- Browser-stored payment-related information where available.
- DPAPI-protected material via local access and abuse of legitimate decryption contexts.

Session cookies are especially dangerous because they can allow an attacker to bypass password resets or MFA in some environments until tokens are revoked or sessions expire.

Cryptocurrency Theft

Lumma searches for local cryptocurrency wallet files, browser wallet extensions, and local keys. Microsoft specifically references wallet targets such as MetaMask, Electrum, and Exodus. This capability creates immediate financial risk for infected cryptocurrency users.

Application and Document Theft

Observed target classes include:

- VPN profiles such as .ovpn.
- Email client data.
- FTP client data.
- Telegram application data.
- User documents in common directories, especially extensions such as .pdf, .docx, and .rtf.
- System metadata, including CPU information, OS version, locale, and installed applications.

Payload and Plugin Support

Lumma can request additional configuration from C2. Microsoft reports observed plugin or additional malware behavior involving clipboard stealer plugins and coin miners. This makes Lumma both a stealer and a potential foothold for additional monetization.

Defense Evasion and Obfuscation

Known or reported evasion characteristics include:

- Heavy binary obfuscation.
- Control-flow flattening and control-flow obfuscation.
- Dead code insertion.
- Stack decryption.
- Low-level syscall usage.
- Heaven's Gate techniques.
- C2 string encryption, including ChaCha20-protected C2 lists in some versions.
- Rapid domain rotation and use of Cloudflare-proxied infrastructure.
- Use of legitimate services or trusted platforms to blend delivery and fallback communication.

Process Injection and Hollowing

Microsoft reports that the Lumma loader may use process hollowing to inject into legitimate processes including:

- `msbuild.exe`
- `regasm.exe`
- `regsvcs.exe`
- `explorer.exe`

This behavior is intended to execute under trusted-looking processes and reduce detection by behavior monitoring tools.

Command and Control

Lumma C2 has evolved across versions. Microsoft identified up to six tracked versions, with changes in domains, URI paths, POST formats, and C2 command patterns. Common traits include:

- Hardcoded tier 1 C2 domains.
- Regularly updated and reordered C2 lists.
- Fallback C2 pointers via Telegram channels and Steam profiles.
- Cloudflare-proxied C2 infrastructure.
- Encrypted HTTPS communication.
- C2 commands used to check connectivity, retrieve configuration, send stolen data, and retrieve plugin or second-stage instructions.

Microsoft described parameters observed in older and newer versions, including `act`, `ver`, `lid`, `uid`, `j`, `cid`, `hwid`, and `pid`. Version 6 reportedly removed the `act` parameter and changed some

identifier fields. For defenders, the key point is that static C2 signatures age quickly; detection should combine domain intelligence with behavioral indicators.

MITRE ATT&CK Mapping

Tactic	Technique	Relevance
Initial Access	T1566.001 Spearphishing Attachment	Lumma campaigns use malicious attachments.
Initial Access	T1566.002 Spearphishing Link	Lumma campaigns use phishing URLs and cloned pages.
Execution	T1059 Command and Scripting Interpreter	PowerShell, JavaScript, and command shell execution are common in delivery chains.
Execution	T1204 User Execution	Fake CAPTCHA, cracked software, and ClickFix flows require user execution.
Defense Evasion	T1027 Obfuscated Files or Information	Lumma binaries and scripts are heavily obfuscated.
Defense Evasion	T1036 Masquerading	Payloads may be embedded in spoofed or fake popular software.
Defense Evasion	T1055 Process Injection	Process injection and hollowing are observed.
Defense Evasion	T1140 Deobfuscate/Decode Files or Information	Samples decode strings and C2 domains at runtime.
Credential Access	T1555.003 Credentials from Web Browsers	Lumma steals browser passwords, cookies, and autofill data.
Collection	T1119 Automated Collection	Lumma collects sensitive files and application data.
Command and Control	T1071.001 Web Protocols	Lumma uses HTTP/HTTPS POST communications.
Exfiltration	TA0010 Exfiltration	Stolen data is sent to attacker-controlled infrastructure.

MITRE also tracks Lumma Stealer as software S1213 and lists browser credential theft as a documented behavior.

Indicators and Detection Opportunities

Indicators change frequently. Use current threat intelligence feeds and vendor detections for domains and hashes. The following behavioral indicators are more durable:

Host-Based Indicators

- Unexpected execution of `mshta.exe`, `powershell.exe`, `cmd.exe`, `curl.exe`, `wscript.exe`, or `cscript.exe` after browser activity.
- Windows RunMRU entries containing PowerShell, `mshta`, `curl`, encoded commands, unusual Unicode, or copied verification-style command artifacts.
- Browser processes followed by scripting engine execution and network connections to newly registered or low-reputation domains.
- DPAPI access by suspicious processes, AutoIt-packed binaries, PowerShell, or .NET framework processes in unusual contexts.
- Process hollowing or injection into `msbuild.exe`, `regasm.exe`, `regsvcs.exe`, or `explorer.exe`.
- New unsigned binaries in user-writable locations such as `%TEMP%`, `%APPDATA%`, `%LOCALAPPDATA%`, or Downloads.
- Archive extraction followed by execution of unsigned utilities or installers.
- Access to browser credential stores, cookie databases, wallet extension folders, VPN profiles, and Telegram data by non-browser processes.

Network Indicators

- HTTPS POST requests from unusual child processes or recently dropped binaries.
- Connections to newly registered, recently rotated, or Cloudflare-proxied domains following suspicious script execution.
- Traffic to domains discovered through Telegram or Steam profile fallback references.
- Repeated POST attempts across multiple candidate C2 domains.

Identity and Cloud Indicators

- New sign-ins from unfamiliar geographies or devices shortly after endpoint infection.
- Token reuse from unknown IPs.
- Suspicious OAuth consent grants.
- Mailbox rule creation or forwarding.
- VPN logins from impossible travel locations.
- Password reset attempts and MFA fatigue following infection.

Sample Hunting Logic

The following examples are defensive hunting patterns and should be adapted to available telemetry.

Suspicious RunMRU Activity

Look for RunMRU registry writes containing scripting tools, encoded commands, `mshta`, or PowerShell patterns after browser activity. This is especially relevant for ClickFix-style lures.

Suspicious Script-to-Network Chain

Hunt for:

```
browser.exe -> powershell.exe / mshta.exe / cmd.exe -> network connection -> dropped executable
```

Add context filters for:

- Parent process from browser, email client, archive utility, or explorer.
- Command line containing `-enc`, `FromBase64String`, `DownloadString`, `iwr`, `irm`, `curl`, `mshta`, or hidden window flags.
- Network destination with low reputation or recent registration.

Browser Store Access by Non-Browser Process

Alert when uncommon processes access:

- Chrome, Edge, Brave, Opera, or Firefox credential and cookie databases.
- Browser extension folders associated with wallet extensions.
- DPAPI-protected browser material.

Process Hollowing Suspects

Investigate unexpected child process or injection behavior involving:

- `msbuild.exe`
- `regasm.exe`
- `regsvcs.exe`
- `explorer.exe`

Prioritize events where the process lineage begins with a downloaded file, script interpreter, archive extraction, or browser-originated process.

Defensive Controls

Recommended controls include:

- Enforce phishing-resistant MFA for critical applications.
- Revoke sessions and refresh tokens after suspected infostealer exposure.
- Disable browser password storage where enterprise password managers are available.
- Enable endpoint tamper protection, EDR block mode, automated investigation, and network protection.

- Use attack surface reduction rules to block obfuscated scripts, JavaScript/VBScript launching downloaded executable content, untrusted executable files, credential theft from LSASS, and abuse of copied or impersonated system tools.
- Block or warn on execution from user-writable directories.
- Restrict script interpreters for non-administrative users where operationally feasible.
- Use application control such as AppLocker or Windows Defender Application Control.
- Apply web filtering and newly registered domain controls.
- Inspect developer workflow downloads from GitHub, package registries, extension marketplaces, and file-sharing sites.
- Block pirated software and software crack sites through acceptable-use policy and technical controls.
- Monitor OAuth app grants and cloud identity sign-ins.
- Centralize logs from EDR, identity provider, email security, proxy, DNS, and VPN systems.

Incident Response Guidance

When Lumma is suspected or confirmed:

1. Isolate the host from the network.
2. Preserve volatile and forensic artifacts if the incident warrants investigation.
3. Collect EDR timeline, process tree, command line, network connections, DNS, registry, browser access, and file events.
4. Identify the initial delivery vector and all downloaded or staged files.
5. Remove malware only after collecting necessary evidence.
6. Reset passwords for accounts used on the infected host, prioritizing privileged, email, VPN, cloud, finance, and developer accounts.
7. Revoke active sessions, refresh tokens, and remembered devices.
8. Review MFA methods for unauthorized additions or changes.
9. Review mailbox rules, forwarding, OAuth grants, cloud sign-ins, and VPN logs.
10. Check for follow-on malware, persistence, lateral movement, or remote access tooling.
11. Inspect cryptocurrency wallets and rotate wallet material if exposure is plausible.
12. Search the environment for matching execution chains, domains, hashes, and behaviors.
13. Notify affected users and business owners according to incident severity and regulatory requirements.

Business Impact

Potential impacts include:

- Account takeover.
- Theft of corporate and personal credentials.
- Theft of browser session cookies.
- Theft of cryptocurrency assets.
- Unauthorized VPN or cloud access.
- Business email compromise.
- Data exposure from local documents and application stores.
- Initial access brokerage.
- Follow-on ransomware activity.
- Brand and compliance impact if customer or regulated data is exposed.

Analyst Assessment

Lumma remains a significant infostealer threat because it combines a mature MaaS business model with flexible distribution. Its affiliates do not need a single delivery path to succeed; they can rotate lures, domains, loaders, fake software, and legitimate-platform abuse. The 2025 disruption materially affected Lumma infrastructure, but the underlying demand for stolen credentials and the affiliate model make resurgence plausible.

The most effective defensive posture is layered. Endpoint malware removal is necessary but insufficient. Organizations should treat Lumma as an identity incident, assume browser-stored secrets may be compromised, and prioritize token revocation, credential reset, cloud log review, and enterprise-wide hunting for related behaviors.

Source Notes

This report is based on public defensive threat intelligence and law-enforcement reporting available as of 2026-06-01.

- Microsoft Security Blog, "Lumma Stealer: Breaking down the delivery techniques and capabilities of a prolific infostealer", 2025-05-21:
<https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/>
- Microsoft On the Issues, "Disrupting Lumma Stealer: Microsoft leads global action against favored cybercrime tool", 2025-05-21:
<https://blogs.microsoft.com/on-the-issues/2025/05/21/microsoft-leads-global-action-against-favored-cybercrime-tool/>
- FBI/CISA Joint Cybersecurity Advisory AA25-141B, "Threat Actors Deploy LummaC2 Malware to Exfiltrate Sensitive Data from Organizations", 2025-05-21:
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141b>
- MITRE ATT&CK, "Lumma Stealer, Software S1213":
<https://attack.mitre.org/software/S1213/>

- Europol, "Europol and Microsoft disrupt world's largest infostealer Lumma", 2025-05-21:
<https://www.europol.europa.eu/media-press/newsroom/news/europol-and-microsoft-disrupt-world%E2%80%99s-largest-infostealer-lumma>